WEEK 4 SPECIALIST ADVANCED BUILD | 100% VERIFIED PASS | OPENAPI 3.0 + EXPRESS.JS

DevPulse Public API Product

Keys, Tiered Rate Limits, Dual-Track Versioning & Interactive OpenAPI Documentation

AUTHOR / ROLE
Ahmed (Member 6)

TRACK
Web Development Specialist

INTERNSHIP PROGRAM
SAFEX / SDC Internship

GITHUB REPOSITORY
github.com/axediqbal/safexWeek4

1 Executive Summary & Business Scope

Business Scenario: DevPulse Labs is an independent software engineering house specializing in static code analysis, software architecture auditing, and automated engineering metrics. Historically, their analytics operated purely as internal CLI utilities.

The Core Objective: Package and monetize DevPulse's proprietary code analysis engine as a commercial, public-facing **API Product** for third-party developer teams, engineering managers, and CI/CD pipelines.

> **Core Features Delivered:** Tiered API key authentication (`x-api-key`), Sliding-Window rate limiting with HTTP `429` and `Retry-After` headers, OpenAPI 3.0 contract specification, interactive Swagger UI portal (`/docs`), and dual-version support (`/api/v1` deprecated vs `/api/v2` modernized production).

2 Week 3 Retrospective & Week 4 Skill Target

WEEK 3 RETROSPECTIVE (E-COMMERCE STOREFRONT)	WEEK 4 SPECIALIST ADVANCED SKILL TARGET
3 Things Done Well: • Client-side cart state persistence with reactive subtotals. • Multi-step checkout flow with real-time field validation. • Custom CSS design tokens and responsive UI. **2 Gaps Identified:** • Absence of contract-first OpenAPI schemas or documentation. • Zero backend ingestion safeguards (no API keys or rate limiting).	**New Specialist Competencies:** • **Schema-First Architecture:** Authoring OpenAPI 3.0 specifications before backend route logic. • **Multi-Tenant Rate Limiting:** Enforcing fair-use limits per tenant using token counters. • **API Lifecycle & Governance:** RFC 8594 Sunset deprecation headers alongside breaking-change v2 schemas. • **Empirical Micro-Benchmarking:** Algorithmic comparison under burst traffic conditions.

3 5-Line Action Plan & Measurable Success Target

1. **Design:** Author OpenAPI 3.0 spec (`openapi.yaml`) defining 5 core data service endpoints.
2. **Auth & Tiers:** Implement Express server with tiered API key middleware (Free, Developer, Enterprise).
3. **Special Constraint:** Implement and micro-benchmark Fixed Window vs Sliding Window rate limiters.
4. **Lifecycle & Portal:** Expose deprecated `/api/v1` with RFC 8594 headers alongside modernized `/api/v2` with live Swagger UI at `/docs`.
5. **Validation:** Build automated burst load tests proving `429 Too Many Requests` triggers accurately.

> **Measurable Success Target:** Automated burst load test on the Free Tier (5 req/60s) must achieve exactly 5 consecutive HTTP 200 OK responses, followed immediately by 100% HTTP 429 Too Many Requests with integer `Retry-After` headers.
> **Result: 100% ACHIEVED (Verified via `scripts/load-test.js`).**

4 Endpoints & API Monetization Tiers

Core Data Service Endpoints

METHOD	ENDPOINT	DESCRIPTION	DEFAULT PARAMETERS
`GET`	`/api/v2/metrics/code-health`	Maintainability grade (A-F), cyclomatic complexity, test coverage.	`?repo=github.com/...`
`GET`	`/api/v2/metrics/security-audit`	Vulnerability count, CVE severity breakdown (Critical, High, Med).	`?repo=github.com/...`
`GET`	`/api/v2/metrics/tech-debt`	Technical debt ratio (%), remediation hours, refactoring cost.	`?repo=github.com/...`
`GET`	`/api/v2/metrics/build-benchmarks`	CI/CD build duration, test pass rate, asset bundle size.	`?repo=github.com/...`
`POST`	`/api/v2/analyze/repository`	Dispatches asynchronous static analysis job; returns synthesis report.	JSON: `repo_url, branch`

Monetization Tiers & Seeded Credentials

TIER	QUOTA LIMIT	WINDOW	SEEDED DEMO API KEY	TARGET CUSTOMER
Free Starter	5 requests	60 seconds	`devpulse_free_demo_key`	Open-source contributors, trial users
Developer Pro	20 requests	60 seconds	`devpulse_pro_demo_key`	SaaS development teams, automated bots
Enterprise Max	100 requests	60 seconds	`devpulse_ent_demo_key`	High-volume CI/CD build matrix runners

5 Special Constraint: Rate Limiting Comparison Benchmark

To satisfy the internship Special Constraint, two rate limiting algorithms were implemented, benchmarked, and evaluated under identical burst load profiles:

METRIC / ATTRIBUTE	APPROACH A: FIXED WINDOW COUNTER	APPROACH B: SLIDING WINDOW COUNTER	SIGNIFICANCE & DECISION
Boundary Burst Vulnerability	**FAILS (Allows 200% Limit)**	**PASSES (Capped at 100%)**	Fixed Window allows 40 requests in 2 seconds across boundary.
Burst Leakage in 2s Gap	40 requests allowed	21 requests allowed	Sliding Window strictly protects downstream databases.
Average Decision Latency	373.1 nanoseconds	561.3 nanoseconds	Both sub-microsecond overhead (< 0.001 ms).
Throughput Capacity	2,679,959 ops/second	1,781,515 ops/second	Negligible CPU overhead difference.
Memory Complexity	O(1) (2 fields per tenant)	O(1) (3 fields per tenant)	Scales to millions of concurrent API keys in memory.
Production Selection	Rejected due to boundary exploit	**SELECTED FOR DEVPULSE**	Industry standard (Stripe & Cloudflare architecture).

Architectural Conclusion: While Fixed Window is slightly simpler, its vulnerability to boundary bursts (2x contracted capacity) poses a severe DDoS risk. Sliding Window Counter provides strict fair-use guarantees at near-zero performance cost.

6 API Versioning & Lifecycle Governance

DevPulse operates a dual-track versioning architecture allowing existing customers to use legacy v1 while migrating to v2:

DIMENSION	LEGACY `/API/V1` (DEPRECATED)	MODERN `/API/V2` (ACTIVE PRODUCTION)
RFC 8594 Headers	`Deprecation: true`, `Sunset: 2026-11-11`, `Link: </api/v2>`	Standard production headers
Response Envelope	Flat unstructured JSON payload	Standardized envelope: `{ status, version, data }`
Field Casing	Legacy `snake_case` (e.g. `health_score`)	Modern `camelCase` (e.g. `healthScore`)
Enriched Metrics	Basic metric counters	Refactoring cost ($), tree-shaking efficiency, CVE score

7 Validation Evidence: Problems Found & Fixed

#	COMPONENT	PROBLEM DIAGNOSED	ROOT CAUSE	FIX IMPLEMENTED & VERIFICATION
1	Benchmark Harness	Simulation allowed 20/20 on both T59 and T61 within Fixed Window.	Base time was not aligned to 60s window boundary.	Introduced `ALIGNED_WINDOW_START` math. Boundary burst accurately reproduced.
2	Performance Loop	`ReferenceError` on variable during 10k benchmark.	Variable name mismatch during boundary refactoring.	Normalized timing variables. 10,000 iterations ran cleanly in 5.61ms.
3	Swagger UI Assets	Direct hit to `/docs` missing CSS styling without trailing slash.	Express routing mount behavior in swagger-ui-express.	Mounted at both `/docs` and `/api-docs`; assets render perfectly.
4	Rate Limiter Headers	`Retry-After` occasionally rounded down to 0s.	Clock millisecond rounding error.	Added `Math.max(1, Math.ceil(...))` guarantee; returns integer seconds.

8 Master Verification Scorecard (6/6 Passed)

TEST SUITE	SCOPE VERIFIED	EXECUTION TIME	RESULT
1. OpenAPI 3.0 Integrity	YAML validation, 5 endpoints, schemas, RFC headers	155ms	✅ 100% PASSED
2. Express Core & Auth	Seeded keys, 401 unauthorized handling, 5 endpoints	203ms	✅ 100% PASSED
3. Rate Limiting Quotas	Free (5), Developer (20), Enterprise (100) tenant quotas	190ms	✅ 100% PASSED
4. Versioning Lifecycle	v1 Deprecation, Sunset headers, v2 schema envelope	211ms	✅ 100% PASSED
5. Special Constraint Benchmark	Fixed Window vs Sliding Window 10,000 op micro-benchmark	90ms	✅ 100% PASSED
6. Burst Load Test	Empirical 200 OK → 429 Too Many Requests transition proof	238ms	✅ 100% PASSED

9 Project Links & Deliverable Checklist

- **GitHub Repository:** https://github.com/axediqbal/safexWeek4
- **Interactive OpenAPI Documentation:** `http://localhost:3000/docs`
- **Developer Portal & React SaaS App:** `http://localhost:3000` and `http://localhost:3000/app`
- **Video Walkthrough Speaking Script:** Complete 5-minute script ready in `VIDEO_WALKTHROUGH_SCRIPT.md`